API — Website Bình chọn Du lịch Nông thôn

Bản bàn giao cập nhật ngày **04/11/2026**, đối chiếu controller, DTO, guard và service trong repository. Backend dùng NestJS + TypeORM + PostgreSQL; đăng nhập email OTP, gửi thư qua Gmail API.

Tài liệu mô tả hành vi đã có trong code, không khẳng định phiên bản này đã được deploy lên mọi môi trường. JSON là ví dụ minh họa: UUID, token, số phiếu và nội dung rút gọn không phải dữ liệu thực tế. Khi tích hợp, lấy ID/slug/token từ response thật.

Quy ước chung

- `BASE_URL` là URL **backend**; source hiện không có prefix `/api`. Ví dụ `{{BASE_URL}}/auth/otp/send`.
- Local dùng `PORT` của backend; production dùng URL Web Service Render. Không dùng URL frontend Vercel thay cho backend.
- Body là JSON, header `Content-Type: application/json`. GET không có body.
- Route cần đăng nhập dùng `Authorization: Bearer <accessToken>`.
- ID là chuỗi UUID, ngày giờ là ISO 8601 có timezone, các thời hạn tính bằng **giây**.
- Thành công trả object trực tiếp, không bọc `{ success, data }`. Riêng `/` trả text, logout không có body.
- Field ngoài DTO bị từ chối 400 ở body Auth/Voting và query Destination. Không gửi `userId` từ client.
- Auth, Voting, Ranking dùng `Cache-Control: no-store`.
- Header `X-Request-Id` dùng khi đối chiếu log lỗi.

Danh sách endpoint

Method	Endpoint	Xác thực	Thành công	Chức năng
GET	`/`	Không	200, text	Kiểm tra ứng dụng
POST	`/auth/otp/send`	Không	202	Gửi OTP lần đầu
POST	`/auth/otp/resend`	Không	202	Gửi lại OTP email
POST	`/auth/otp/verify`	Không	200	Xác thực, đăng nhập/tạo user

Method	Endpoint	Xác thực	Thành công	Chức năng
POST	`/auth/refresh`	Refresh Token trong body	200	Đổi cặp token
POST	`/auth/logout`	Refresh Token trong body	204	Thu hồi session
GET	`/auth/me`	Bearer	200	Thông tin user
GET	`/destinations`	Không	200	Danh sách, phân trang, tìm kiếm
GET	`/destinations/:slug`	Không	200	Chi tiết và ảnh/video
POST	`/votes`	Bearer	201	Bình chọn
GET	`/votes/me`	Bearer	200	Phiếu đã bỏ và lượt còn lại
GET	`/rankings/top`	Không	200	Top 3 hiện tại
GET	`/rankings`	Không	200	Toàn bộ bảng xếp hạng

Chi tiết request và response

1. Kiểm tra ứng dụng — `GET /`

```
GET {{BASE_URL}}/
```

Request body: không có.

Không có request body. Response `Content-Type: text/html; charset=utf-8` , body là chuỗi `Hello World!` . Đây là route kiểm tra ứng dụng khởi động, không trả trạng thái chi tiết của từng dịch vụ.

Response 200 OK

```
Hello World!
```

2. Gửi OTP email — `POST /auth/otp/send`

```
POST {{BASE_URL}}/auth/otp/send
Content-Type: application/json
```

Request body

```
{
  "email": "user@example.com"
}
```

Validation: `email` bắt buộc, string hợp lệ, tối đa 254 ký tự; backend trim và lowercase. Không tự bỏ dấu chấm hoặc phần `+alias`.

Quy tắc hiện tại:

- `send` tối đa 1 lần/email/giờ; `resend` tối đa 3 lần/email/giờ; tổng không vượt 4 lần trong cửa sổ trượt 1 giờ. Gọi lại `send` trong giờ bị 429 kể cả đã qua cooldown, mã cũ hết hạn hoặc đã xác thực.
- Chờ ít nhất 60 giây giữa các lần gửi. Gửi lại phải dùng `/auth/otp/resend`; không dùng lại `/auth/otp/send`.
- OTP ngẫu nhiên 6 chữ số, mặc định hiệu lực 300 giây, chỉ dùng một lần và chỉ lưu HMAC/hash.
- Không trả OTP hoặc số lần resend còn lại trong response. `retryAfter` chỉ là thời gian chờ gửi lại, không bảo đảm còn quota giờ.
- Mã mới vô hiệu mã cũ. Gửi lỗi sau khi challenge đã được tạo vẫn tính quota và challenge đó bị vô hiệu.
- Chưa tạo tài khoản ở bước gửi. HTTP 202 nghĩa là Gmail nhận lệnh gửi, không bảo đảm thư đã vào Inbox.
- Giới hạn IP dùng chung send + resend: tổng 5 request/phút. Client dùng `expiresIn`, `retryAfter` từ response thay vì hardcode.

Lỗi: 400 email/body không hợp lệ; 429 vượt cooldown/hạn mức email hoặc IP; 503 chưa cấu hình/gửi thư thất bại.

Response 202 Accepted

```
{
  "message": "OTP đã được gửi.",
  "expiresIn": 300,
  "retryAfter": 60
}
```

3. Gửi lại OTP email — `POST /auth/otp/resend`

```
POST {{BASE_URL}}/auth/otp/resend
Content-Type: application/json
```

Request body

```
{
  "email": "user@example.com"
}
```

Email dùng cùng validation và chuẩn hóa với `/auth/otp/send`. Không cần đăng nhập.

- Cần có lần gửi đầu `SEND` cho email này trong một giờ gần nhất; nếu chưa có hoặc lần gửi đầu đã ra ngoài cửa sổ một giờ, trả 400 và yêu cầu gọi `/auth/otp/send` trước.
- Tối đa **3 lần RESEND/email/giờ**, tách biệt với 1 lần SEND; tổng vẫn không vượt 4 theo cấu hình. Không dùng lại `send` để né giới hạn.
- Cách lần gửi trước (send hoặc resend) ít nhất **60 giây**.
- Sinh OTP ngẫu nhiên mới, vô hiệu mã cũ. Mã mới có tối đa 3 lần nhập sai, kể cả mã trước đã hết hạn hoặc bị khóa do nhập sai.
- Gửi lỗi sau khi đã tạo challenge vẫn tính một lần resend; challenge đó bị vô hiệu.
- Không nhận `requestType`, `userId` hoặc số lượt do client truyền. Loại yêu cầu do endpoint quyết định và được lưu vào database.
- Send và resend dùng chung giới hạn IP 5 request/phút.

Response 202 Accepted

```
{
  "message": "OTP đã được gửi.",
  "expiresIn": 300,
  "retryAfter": 60
}
```

Lỗi: 400 email/body sai hoặc chưa có SEND trong một giờ gần nhất; 429 quá sớm, hết lượt resend hoặc vượt quota/IP; 503 dịch vụ gửi thư không sẵn sàng. Không trả OTP hoặc số lần resend còn lại.

4. Xác thực OTP / Đăng nhập — `POST /auth/otp/verify`

```
POST {{BASE_URL}}/auth/otp/verify
Content-Type: application/json
```

Request body

```
{
  "email": "user@example.com",
  "otp": "012345"
}
```

Validation: `email` như endpoint gửi OTP; `otp` là **string đúng 6 chữ số**. Giữ số 0 đầu, không gửi number.

- OTP sai tối đa **3 lần/mã**; sai lần thứ 3 khóa mã. Gửi lại tạo mã mới, số lần thử của mã mới bắt đầu từ 0.
- Mã đã dùng, hết hạn, bị thay thế hoặc bị khóa không xác thực được. Hai request đồng thời không dùng cùng mã thành công hai lần.
- Xác thực đúng mới tạo user nếu chưa tồn tại; user có sẵn giữ nguyên UUID.
- Access Token là JWT sống 900 giây. Refresh Token là opaque `<session UUID>.<secret base64url 43 ký tự>` , không phải JWT.
- Session ban đầu có thời hạn 30 ngày; `refreshExpiresIn` là thời gian còn lại.
- Giới hạn IP: 15 request/phút.

Lỗi: 400 sai DTO; 401 OTP sai/hết hạn/đã dùng/khóa hoặc user bị chặn; 429 vượt giới hạn IP.

Response 200 OK

```
{
  "accessToken": "<JWT_ACCESS_TOKEN>",
  "refreshToken": "<SESSION_UUID>.<RANDOM_SECRET>",
  "tokenType": "Bearer",
  "expiresIn": 900,
  "refreshExpiresIn": 2592000,
  "user": {
    "id": "f4d3504c-0f32-4a3c-84c8-8e9e31e4c6c5",
    "email": "user@example.com",
    "createdAt": "2026-11-04T08:00:00.000Z"
  }
}
```

5. Refresh token — `POST /auth/refresh`

```
POST {{BASE_URL}}/auth/refresh
Content-Type: application/json
```

Request body

```
{
  "refreshToken": "<REFRESH_TOKEN_HIEN_TAI>"
}
```

Request: dùng Refresh Token mới nhất từ lần đăng nhập/refresh gần nhất, không cần Bearer Token.

- Thành công trả cấu trúc như đăng nhập, thay **cả Access Token và Refresh Token**.
- Token cũ không dùng lại được sau rotation. Client chỉ refresh một lần tại một thời điểm cho cùng session.
- `refreshExpiresIn` giảm theo thời gian; refresh không kéo dài mốc hết hạn tuyệt đối 30 ngày.

Lỗi: 400 Refresh Token sai định dạng; 401 token/session không hợp lệ, hết hạn, bị thu hồi hoặc user bị chặn; 429 vượt giới hạn Auth.

Response 200 OK

```
{
  "accessToken": "<NEW_JWT_ACCESS_TOKEN>",
  "refreshToken": "<SESSION_UUID>.<NEW_RANDOM_SECRET>",
  "tokenType": "Bearer",
  "expiresIn": 900,
  "refreshExpiresIn": 2500000,
  "user": {
    "id": "f4d3504c-0f32-4a3c-84c8-8e9e31e4c6c5",
    "email": "user@example.com",
    "createdAt": "2026-11-04T08:00:00.000Z"
  }
}
```

6. Đăng xuất — `POST /auth/logout`

```
POST {{BASE_URL}}/auth/logout
Content-Type: application/json
```

Request body

```
{
  "refreshToken": "<REFRESH_TOKEN_HIEN_TAI>"
}
```

Dùng Refresh Token mới nhất, không cần Bearer Token. **204 không có JSON body** nên client không gọi `response.json()` .

Thu hồi session tương ứng; Access Token của session đó bị từ chối ở request sau. Client xóa token local. Token đúng định dạng nhưng đã bị thu hồi/không còn hợp lệ vẫn trả 204; body sai định dạng trả 400. Có thể trả 429 theo giới hạn Auth.

Response 204 No Content

Không có body.

7. Thông tin user — `GET /auth/me`

```
GET {{BASE_URL}}/auth/me
Authorization: Bearer <accessToken>
```

Request body: không có.

Không có body. `email` có thể `null` với tài khoản phone cũ được giữ lại; user xác thực bằng email có email đã xác minh. Không trả hash hoặc số điện thoại.

Lỗi: 401 khi thiếu/sai/hết hạn Access Token, session bị thu hồi/hết hạn hoặc user bị chặn; 429 theo giới hạn Auth.

Response 200 OK

```
{
  "id": "f4d3504c-0f32-4a3c-84c8-8e9e31e4c6c5",
  "email": "user@example.com",
  "createdAt": "2026-11-04T08:00:00.000Z"
}
```

8. Danh sách điểm đến — `GET /destinations`

```
GET {{BASE_URL}}/destinations?page=1&limit=12&keyword=Lê%20Phúc
```

Request body: không có.

Không cần đăng nhập. Query:

Tên	Kiểu	Mặc định	Ràng buộc
`page`	integer	1	1–100000
`limit`	integer	12	1–100
`keyword`	string	Không lọc	Trim; tối đa 100 ký tự

- Chỉ trả điểm đến active. Tìm trong `title`, `brief`, `province`, không phân biệt hoa/thường; chưa có tìm kiếm bỏ dấu.
- Sắp xếp `displayOrder ASC`, sau đó UUID `id ASC` để ổn định.
- `total` là số kết quả sau lọc; `totalPages = ceil(total / limit)`.
- Không có kết quả: `items: []`, `total: 0`, `totalPages: 0`. Vượt trang cuối có thể `items: []` nhưng tổng vẫn lớn hơn 0.
- `province`, `thumbnailUrl` có thể `null`. Danh sách không trả `detail`, `media` hoặc số phiếu; lấy số phiếu từ Ranking.

Lỗi: 400 query không hợp lệ hoặc có field ngoài DTO.

Response 200 OK


```
{
  "items": [
    {
      "id": "ba05ed6c-cf82-4686-a02f-000000000025",
      "title": "Điểm du lịch “Vườn hồng Lê Phúc”",
      "slug": "dlnt2026-025-diem-du-lich-vuon-hong-le-phuc",
      "brief": "Nội dung mô tả ngắn của điểm đến.",
      "province": "Đà Lạt",
      "thumbnailUrl": null,
      "displayOrder": 25
    }
  ],
  "total": 1,
  "page": 1,
  "limit": 12,
  "totalPages": 1
}
```

9. Chi tiết điểm đến — `GET /destinations/dlnt2026-025-diem-du-lich-vuon-hong-le-phuc`

```
GET {{BASE_URL}}/destinations/dlnt2026-025-diem-du-lich-vuon-hong-le-phuc
```

Request body: không có.

Path nhận **slug**, không phải UUID. Ví dụ trên dùng slug của bài 25; slug bắt buộc dài 1–255 ký tự.

- Gồm toàn bộ field tóm tắt, thêm `detail` và `media`.
- `detail` là chuỗi nội dung; dữ liệu nhập hiện có Markdown. Nếu render thành HTML, client cần xử lý và sanitize phù hợp.
- Media sắp theo `displayOrder ASC`, sau đó `id ASC`.
- `mediaType`: `IMAGE` hoặc `VIDEO`; `caption` có thể `null`; chưa có media trả `[]`.
- 35 bài thi đã được gắn link Vimeo. `mediaUrl` là link Vimeo, **không phải MP4**, nên không gắn trực tiếp vào thẻ `<video src>`.
- Frontend dùng Vimeo player/iframe. Giữ hash của video unlisted ở bài 1 khi tạo link nhúng; API hiện không trả field `embedUrl` hoặc `provider` riêng.
- Ảnh đại diện chưa có có thể vẫn `null`; client cần ảnh fallback. Quyền phát/nhúng phụ thuộc cấu hình Vimeo.

Lỗi: 400 slug không hợp lệ; 404 không tồn tại hoặc không active.

Response 200 OK

```
{
  "id": "ba05ed6c-cf82-4686-a02f-000000000025",
  "title": "Điểm du lịch “Vườn hồng Lê Phúc”",
  "slug": "dlnt2026-025-diem-du-lich-vuon-hong-le-phuc",
  "brief": "Nội dung mô tả ngắn của điểm đến.",
  "province": "Đà Lạt",
  "thumbnailUrl": null,
  "displayOrder": 25,
  "detail": "**Mã hồ sơ:** DLNT2026-025\n\n## Nội dung hồ sơ\n\nNội dung chi tiết bài dự th
  "media": [
    {
      "id": "d1202026-0000-4000-8000-000000000025",
      "mediaType": "VIDEO",
      "mediaUrl": "https://vimeo.com/1243133653",
      "caption": "Video bài dự thi DLNT2026-025",
      "displayOrder": 1
    }
  ]
}
```


10. Bình chọn — `POST /votes`

```
POST {{BASE_URL}}/votes
Authorization: Bearer <accessToken>
Content-Type: application/json
```

Request body


```
{
  "destinationId": "ba05ed6c-cf82-4686-a02f-000000000025"
}
```


Validation: `destinationId` là UUID lấy từ API điểm đến. Không gửi `slug`, `userId` hoặc email để định danh người bình chọn; backend lấy user từ Access Token.

- Mỗi tài khoản tối đa **3 phiếu trong toàn hội thi**, không phải mỗi ngày. Không bình chọn cùng điểm đến hai lần.
- Không có API hủy, sửa hoặc chuyển phiếu.
- Điểm đến phải tồn tại và active; backend kiểm tra thời gian bằng đồng hồ PostgreSQL sau khi lấy khóa.

- Lịch chỉ mở khi cấu hình đủ `VOTING_START_AT` và `VOTING_END_AT`; source chấp nhận `start <= now <= end`. Không tự suy đoán giờ mở/đóng từ ngày 05–20/11/2026.
- Thiếu lịch chính thức thì đóng. Thời gian mở/đóng chưa được trả qua một API công khai riêng.
- Transaction và khóa user bảo vệ giới hạn khi có request đồng thời.
- Response chỉ trả phiếu vừa tạo; gọi lại `/votes/me` để lấy số lượt, `/rankings/top` và `/rankings` để lấy thứ hạng mới.

HTTP	Trường hợp
400	Sai UUID/body hoặc điểm đến không nhận bình chọn
401	Thiếu/sai token, session không hợp lệ, user bị chặn ở guard
403	Hội thi chưa mở/đã đóng hoặc user bị chặn phát hiện trong transaction
404	Không tìm thấy điểm đến
409	Trùng điểm đến hoặc đã dùng hết lượt

Với cấu hình mặc định, hết lượt có message `Bạn đã dùng hết 3 lượt bình chọn.`; trùng điểm đến có message `Bạn đã bình chọn cho điểm đến này.`.

Response 201 Created

```
{
  "id": "b13db255-c8db-4c29-b514-9b96545b9a9b",
  "destinationId": "ba05ed6c-cf82-4686-a02f-000000000025",
  "createdAt": "2026-11-05T03:15:00.000Z"
}
```

11. Lượt bình chọn của tôi — `GET /votes/me`

```
GET {{BASE_URL}}/votes/me
Authorization: Bearer <accessToken>
```

Request body: không có.

Không có body/query. Phiếu sắp theo thời điểm tạo rồi ID.

- `usedVotes`: số phiếu đã bỏ; `remainingVotes`: số lượt còn lại; `maxVotes`: hạn mức đang cấu hình, mặc định 3.
- Chưa bỏ phiếu: `items: []`, `usedVotes: 0`, `remainingVotes: 3`, `maxVotes: 3` ở cấu hình mặc định.

- Điểm đến bị ẩn sau khi bỏ phiếu vẫn xuất hiện trong lịch sử và vẫn tính lượt đã dùng; không hoàn lượt.
- Object `destination` là bản tóm tắt, không có `detail` hoặc `media`.

Lỗi: 401 thiếu/sai/hết hạn token hoặc session/user không hợp lệ.

Response 200 OK


```
{
  "items": [
    {
      "id": "b13db255-c8db-4c29-b514-9b96545b9a9b",
      "destinationId": "ba05ed6c-cf82-4686-a02f-000000000025",
      "createdAt": "2026-11-05T03:15:00.000Z",
      "destination": {
        "id": "ba05ed6c-cf82-4686-a02f-000000000025",
        "title": "Điểm du lịch “Vườn hồng Lê Phúc”",
        "slug": "dlnt2026-025-diem-du-lich-vuon-hong-le-phuc",
        "brief": "Nội dung mô tả ngắn của điểm đến.",
        "province": "Đà Lạt",
        "thumbnailUrl": null,
        "displayOrder": 25
      }
    }
  ],
  "usedVotes": 1,
  "remainingVotes": 2,
  "maxVotes": 3
}
```


12. Top 3 điểm đến — `GET /rankings/top`

```
GET {{BASE_URL}}/rankings/top
```

Request body: không có.

Không có body/query, không cần đăng nhập. Lấy **tối đa 3 điểm đến đứng đầu tại thời điểm truy vấn**; ít hơn 3 điểm active thì trả ít hơn 3.

Ví dụ minh họa có 4 điểm active, tổng 120 phiếu; Top 3 trả 3 điểm, nhưng `totalDestinations` vẫn bằng 4 và `totalVotes` vẫn là tổng toàn bộ điểm active.

Backend đếm trực tiếp bảng phiếu và sắp xếp mỗi request; không lưu bảng tổng điểm riêng. Đọc thêm quy tắc xếp hạng ở mục kế tiếp.

Response 200 OK


```
{
  "items": [
    {
      "id": "ba05ed6c-cf82-4686-a02f-000000000025",
      "title": "Điểm du lịch “Vườn hồng Lê Phúc”",
      "slug": "dlnt2026-025-diem-du-lich-vuon-hong-le-phuc",
      "brief": "Nội dung mô tả ngắn của điểm đến.",
      "province": "Đà Lạt",
      "thumbnailUrl": null,
      "displayOrder": 25,
      "voteCount": 60,
      "rank": 1
    },
    {
      "id": "ba05ed6c-cf82-4686-a02f-000000000001",
      "title": "Làng văn hóa du lịch cộng đồng thôn Bản Khun",
      "slug": "dlnt2026-001-lang-van-hoa-du-lich-cong-dong-thon-ban-khun-xa-bang-lang-tinh-
      "brief": "Nội dung mô tả ngắn của điểm đến.",
      "province": "Tuyên Quang",
      "thumbnailUrl": null,
      "displayOrder": 1,
      "voteCount": 40,
      "rank": 2
    },
    {
      "id": "ba05ed6c-cf82-4686-a02f-000000000007",
      "title": "Khu bảo tồn làng nhà sàn dân tộc sinh thái Thái Hải",
      "slug": "dlnt2026-007-khu-bao-ton-lang-nha-san-dan-toc-sinh-thai-thai-hai",
      "brief": "Nội dung mô tả ngắn của điểm đến.",
      "province": "Thái Nguyên",
      "thumbnailUrl": null,
      "displayOrder": 7,
      "voteCount": 20,
      "rank": 3
    }
  ],
  "totalVotes": 120,
  "totalDestinations": 4
}
```

13. Toàn bộ bảng xếp hạng — `GET /rankings`

```
GET {{BASE_URL}}/rankings
```

Request body: không có.

Không cần đăng nhập, không có body, phân trang hoặc bộ lọc. Ví dụ dưới đây mô tả trọn một bảng minh họa có 4 điểm, gồm một điểm 0 phiếu.

Quy tắc chung cho hai API Ranking:

- Chỉ gồm điểm đến active, kể cả 0 phiếu.
- Thứ tự: `voteCount DESC`, sau đó `displayOrder ASC`, sau đó `id ASC`.
- `rank` là vị trí 1, 2, 3... sau phân xử, không đồng hạng.
- `voteCount`, `rank`, `totalVotes`, `totalDestinations` là JSON number.
- `totalVotes` chỉ tính phiếu của các điểm active; phiếu thuộc điểm đã bị ẩn không nằm trong tổng này.
- Không có điểm active: `items: []`, `totalVotes: 0`, `totalDestinations: 0`.
- Response không có media/video; mở chi tiết điểm đến để lấy.

Cập nhật trên giao diện: frontend polling 5 giây/lần (hoặc 5–10 giây tùy nhu cầu). Sau khi bình chọn thành công, refetch cả Top 3, bảng đầy đủ và `/votes/me` ngay. Chưa có SSE/WebSocket hoặc push realtime; frontend chỉ thấy thay đổi khi gọi API mới.

Response 200 OK

```
{
  "items": [
    {
      "id": "ba05ed6c-cf82-4686-a02f-000000000025",
      "title": "Điểm du lịch “Vườn hồng Lê Phúc”",
      "slug": "dlnt2026-025-diem-du-lich-vuon-hong-le-phuc",
      "brief": "Nội dung mô tả ngắn của điểm đến.",
      "province": "Đà Lạt",
      "thumbnailUrl": null,
      "displayOrder": 25,
      "voteCount": 60,
      "rank": 1
    },
    {
      "id": "ba05ed6c-cf82-4686-a02f-000000000001",
      "title": "Làng văn hóa du lịch cộng đồng thôn Bản Khun",
      "slug": "dlnt2026-001-lang-van-hoa-du-lich-cong-dong-thon-ban-khun-xa-bang-lang-tinh-
      "brief": "Nội dung mô tả ngắn của điểm đến.",
      "province": "Tuyên Quang",
      "thumbnailUrl": null,
      "displayOrder": 1,
      "voteCount": 40,
      "rank": 2
    },
    {
      "id": "ba05ed6c-cf82-4686-a02f-000000000007",
      "title": "Khu bảo tồn làng nhà sàn dân tộc sinh thái Thái Hải",
      "slug": "dlnt2026-007-khu-bao-ton-lang-nha-san-dan-toc-sinh-thai-thai-hai",
      "brief": "Nội dung mô tả ngắn của điểm đến.",
      "province": "Thái Nguyên",
      "thumbnailUrl": null,
      "displayOrder": 7,
      "voteCount": 20,
      "rank": 3
    },
    {
      "id": "ba05ed6c-cf82-4686-a02f-000000000035",
      "title": "Hành trình trải nghiệm Sen Quê Bác",
      "slug": "dlnt2026-035-hanh-trinh-trai-nghiem-sen-que-bac",
      "brief": "Nội dung mô tả ngắn của điểm đến.",
      "province": "Nghệ An",
      "thumbnailUrl": null,
      "displayOrder": 35,
      "voteCount": 0,
      "rank": 4
```

```
    }
  ],
  "totalVotes": 120,
  "totalDestinations": 4
}
```

Lỗi và giới hạn chung

Response lỗi chung:

```
{
  "statusCode": 401,
  "message": "OTP không hợp lệ, đã sử dụng hoặc hết hạn.",
  "error": "Unauthorized",
  "path": "/auth/otp/verify",
  "timestamp": "2026-11-04T08:00:00.000Z",
  "requestId": "7d767251-cbdf-43bf-b83b-918d4eb555ee"
}
```

`message` có thể là string hoặc string[] khi validation thất bại:

```
{
  "statusCode": 400,
  "message": ["email phải là địa chỉ email hợp lệ"],
  "error": "Bad Request",
  "path": "/auth/otp/send",
  "timestamp": "2026-11-04T08:00:00.000Z",
  "requestId": "7d767251-cbdf-43bf-b83b-918d4eb555ee"
}
```

Lỗi gửi thư ví dụ:

```
{
  "statusCode": 503,
  "message": "Internal server error",
  "error": "Service Unavailable",
  "path": "/auth/otp/send",
  "timestamp": "2026-11-04T08:00:00.000Z",
  "requestId": "7d767251-cbdf-43bf-b83b-918d4eb555ee"
}
```

- Filter che chi tiết mọi lỗi 5xx bằng `Internal server error` , không trả lỗi gốc/token Google.

- API hiện **không có field `code` nghiệp vụ** như `OTP_EXPIRED` hay `ALREADY_VOTED`. Không giả định có các field này.
- Dùng HTTP status và message để xử lý giao diện; gửi `requestId` khi cần BE tra lỗi.
- Auth có IP throttling: send và resend dùng chung 5/phút, verify 15/phút, refresh/logout/me mặc định 60/phút. Không áp các mức này như thể đã có cho toàn bộ API Destination/Voting/Ranking.
- Bộ đếm IP hiện ở RAM mỗi instance và reset khi restart; hạn mức email/cooldown dùng database.
- Chưa tích hợp Turnstile/CAPTCHA, giới hạn tổng số thư toàn hệ thống hoặc bộ đếm IP dùng chung nhiều instance.

Luồng tích hợp

1. Nhập email → gửi OTP → hiển thị bộ đếm từ `expiresIn` và `retryAfter`.
2. Gửi lại dùng `/auth/otp/resend`; không tự gửi liên tục. Response không có số lượt resend còn lại nên client không coi bộ đếm local là nguồn quyết định hạn mức.
3. Nhập OTP dạng string → verify → nhận token pair và user.
4. Gắn Bearer cho `/auth/me`, `/votes`, `/votes/me`.
5. Khi API cần xác thực trả 401, thử refresh có điều phối; nếu refresh thành công thì thay cả hai token. Refresh bị từ chối thì xóa phiên và yêu cầu đăng nhập lại.
6. Không tự gửi lại POST bình chọn khi mạng timeout: kiểm tra `/votes/me` trước vì request trước có thể đã thành công. Không tự retry gửi OTP vô hạn.
7. Dùng UUID để gửi vote, dùng slug để mở trang chi tiết. Refetch sau khi bỏ phiếu và polling Ranking.
8. Logout với Refresh Token mới nhất, không parse JSON của response 204, xóa phiên phía client.

Phạm vi hiện có và bàn giao triển khai

- 12 API nghiệp vụ + 1 route kiểm tra ứng dụng như danh sách trên. Không có Admin CRUD, upload media, lấy OTP công khai, hủy/sửa phiếu hay endpoint cài OAuth.
- 35 bài thi đã được seed video Vimeo. Các link trùng trong danh sách cung cấp được giữ nguyên; không giả định một URL chỉ thuộc một bài.
- Gmail OAuth credential chỉ ở backend. Người dùng website không phải đăng nhập/cấp quyền Gmail để nhận OTP.
- Chưa có cookie session tự động: token được trả trong JSON; client chọn cơ chế lưu phiên phù hợp với kiến trúc ứng dụng.
- Source hiện chưa gọi `app.enableCors()`. Trình duyệt gọi frontend/backend khác origin cần cấu hình CORS hoặc qua server/proxy frontend. CORS không thay thế bảo vệ API khỏi spam.
- Dùng HTTPS ở production. Trên Render cần cập nhật đúng các biến môi trường và deploy code mới; `.env` local không tự đồng bộ.

File Postman đi kèm

Import `dulichnongthon.postman_collection.json`. Điền `BASE_URL`, `email`, `otp`, `destinationId`, `slug`, `accessToken`, `refreshToken` bằng dữ liệu thật. Collection không chứa secret, không tự gửi request, không tự lấy token và không tự bình chọn. Các response trong collection là ví dụ minh họa như tài liệu.